École Supérieure des Communications de Tunis

SUP'COM

PhantomOps

Hidden in plain sight. Unseen in transit.



CAHIER DES CHARGES

Réalisé par :

Mohamed Fourat Boujdaria

Cheikh Brahim

Classe : INDP3 CySeD

Année Universitaire : 2026–2027

Table des matières

1 Présentation générale **2**
1.1 Contexte . . . 2
1.2 Problématique et objectifs . . . 2
1.3 Équipe et dépôt GitHub . . . 2

2 Acteurs et périmètre **3**
2.1 Acteurs et rôles . . . 3
2.2 Dimensionnement pour un binôme . . . 3
2.3 Exclusions assumées . . . 4

3 Besoins fonctionnels **4**
3.1 Fonctionnalités retenues (Must) . . . 4
3.2 Règles de gestion . . . 5
3.3 Scénarios principaux . . . 6

4 Conception technique **7**
4.1 Architecture . . . 7
4.2 Paramètres cryptographiques . . . 8
4.3 Modèle de données . . . 9
4.4 Exigences non fonctionnelles . . . 9

5 Sécurité **9**
5.1 Approche SRE : les cas d'abus . . . 9
5.2 Périmètre de l'analyse . . . 9
5.3 Correspondance avec le programme du cours . . . 10

6 Organisation du projet **10**
6.1 Planning . . . 10
6.2 Répartition et méthode de travail . . . 10
6.3 Risques et plan de repli . . . 11

1 Présentation générale

1.1 Contexte

PhantomOps est une plateforme fictive de distribution sécurisée d'informations entre deux agences gouvernementales : VOSTOK et LONGWEI, représentant deux agences fédérales internationales fictives.

Dans le cadre d'un accord de coopération bilatérale, les deux organisations doivent pouvoir échanger des rapports confidentiels et des documents stratégiques, sous forme de contenus textuels de taille limitée dans la version de base (cf. section 2.2). Le système vise à assurer la confidentialité des informations, l'authenticité des correspondants, l'intégrité des documents et la traçabilité de leur distribution, dans les limites des hypothèses de confiance.

La plateforme repose sur l'association de plusieurs mécanismes :

— **Stéganographie** : dissimulation de messages dans des images.

— **Watermarking** : insertion de marques numériques permettant d'identifier l'origine des médias.

— **Fingerprinting** : identification individualisée des copies distribuées.

— **Cryptographie** : chiffrement et signatures numériques.

— **PKI** : gestion centralisée des identités et certificats numériques.

Le système intègre également des mécanismes de contrôle d'accès, d'audit et de surveillance des activités sensibles. Il s'agit d'une simulation académique utilisant exclusivement des identités et des informations fictives.

1.2 Problématique et objectifs

Comment échanger des rapports confidentiels sur des canaux non maîtrisés (messagerie, partage de fichiers), en rendant l'échange discret pour un observateur du canal, en authentifiant l'expéditeur et en traçant la diffusion non autorisée d'une image livrée, face à un serveur honnête mais curieux ?

— **O1** : faire de la dissimulation d'information le cœur métier de l'application.

— **O2** : assurer confidentialité, intégrité et authenticité des rapports de bout en bout, y compris vis-à-vis d'un serveur honnête mais curieux.

— **O3** : gérer l'identité des agents par une PKI privée (certificats X.509 et cycle de vie).

— **O4** : appliquer les chapitres du cours sur un système réaliste, avec des exigences de sécurité traçables jusqu'aux tests.

1.3 Équipe et dépôt GitHub

— **Équipe 8 (binôme)** : Mohamed Fourat Boujdaria, Cheikh Brahim.

— **Cadre** : Atelier Sécurité applicative, SUP'COM, 3e année cycle ingénieur, option CySeD. Enseignant : Dr. Ing. Mohamed-Bécha Kaâniche.

— **Dépôt** : `https://github.com/brahim403/secure-information-hiding`, organisé en `/docs` (PDF), `/backend`, `/frontend`, `/hiding-engine`, `/infra` (Docker Compose, CA) et `/tests`.

2 Acteurs et périmètre

2.1 Acteurs et rôles

Rôle	Description	Droits principaux
Agent (VOSTOK ou LONGWEI)	Émetteur et destinataire	Enrôler ses clés, envoyer vers l'autre agence, consulter ses livraisons, extraire et vérifier.
Administrateur	Gère comptes, certificats et alertes	Inviter, désactiver, approuver et révoquer des certificats, lancer une vérification de fuite, consulter les alertes. Aucun accès direct aux rapports.
Auditeur (Should)	Lecture seule	Consulter le journal d'audit.

2.2 Dimensionnement pour un binôme

Les exigences de sécurité sont identiques pour toutes les équipes ; seul le métier est dimensionné à l'effectif :

- un seul format porteur (PNG sans perte) et un seul type de contenu : texte $\leq$ 16 Ko ;
- un seul moteur de marquage, utilisé en deux modes : filigrane (origine, identique pour toutes les copies d'un rapport) et empreinte (unique par destinataire et par livraison) ;
- une seule CA privée, révocation par CRL, sans OCSP ;
- aucune primitive cryptographique ni CA écrite par l'équipe : API standard du navigateur et outillage existant.

2.3 Exclusions assumées

Exclusion	Conséquence
Robustesse à la compression JPEG, au redimensionnement, au recadrage	Marques et message détruits par réencodage ; traçabilité valable seulement pour les fuites sans perte.
Résistance à la stéganalyse	Camouflage raisonnable, pas d'indétectabilité face à un adversaire statistique.
Résistance à la collusion (comparaison de plusieurs copies)	Risque traité parmi les cas d'abus.
Récupération d'une clé privée perdue	Perte de la clé = nouvel enrôlement ; anciens rapports illisibles.
Serveur servant un code client malveillant	Limite connue du chiffrement de bout en bout dans le web ; atténuée par CSP stricte, SRI et service worker versionné.
CA maison, OCSP, multi-CA, HSM, application mobile native	Hors périmètre : CA outillée, PWA uniquement.
Divulgation du texte déchiffré par son destinataire	Aucune marque dans le texte : seul le journal d'audit établit que le destinataire a pu lire le rapport.

3 Besoins fonctionnels

3.1 Fonctionnalités retenues (Must)

ID	Module	Fonctionnalité
EF-01	Comptes et PKI	Invitation d'un agent par l'administrateur (pas d'inscription ouverte) et activation du compte
EF-02	Comptes et PKI	Authentification et fermeture de session
EF-03	Comptes et PKI	Enrôlement : génération dans le navigateur de deux paires de clés non exportables (signature ECDSA, accord de clé ECDH) ; demande de certificat X.509 d'identité pour la clé de signature ; publication de la clé publique ECDH dans un lot signé par la clé d'identité ; approbation par l'administrateur ; émission du certificat par la CA privée
EF-04	Comptes et PKI	Révocation d'un certificat, publication de la CRL, refus des certificats révoqués
EF-05	Comptes et PKI	Annuaire des certificats valides et des lots de clés de chiffrement de l'agence partenaire
EF-06	Échange	Rédaction d'un rapport (texte $\leq$ 16 Ko) et choix d'un destinataire de l'autre agence

ID	Module	Fonctionnalité
EF-07	Échange	Chiffrement hybride pour le destinataire et signature de l'expéditeur, dans le navigateur
EF-08	Échange	Dépôt d'une image porteuse PNG avec contrôles de validité
EF-09	Échange	Dissimulation du paquet chiffré et signé dans l'image (LSB à positions pseudo-aléatoires), avec contrôle de capacité
EF-10	Échange	Application du filigrane et de l'empreinte à la livraison
EF-11	Échange	Boîtes d'envoi et de réception ; téléchargement de l'image par le seul destinataire désigné
EF-12	Échange	Extraction du paquet (serveur), puis déchiffrement et vérification de la signature (navigateur)
EF-13	Traçabilité	Vérification de fuite : soumission d'une image suspecte, extraction et vérification des marques, identification de la livraison
EF-14	Traçabilité	Journal d'audit des événements de sécurité et consultation filtrée
EF-15	Administration	Gestion des utilisateurs (désactivation, rôles)
EF-16	PWA	Application installable (manifeste, service worker limité au shell applicatif)
EF-17	Surveillance	Alertes de sécurité : règles de détection simples (échecs d'authentification répétés, échecs d'extraction répétés, révocation de certificat, demande de vérification de fuite) signalées à l'administrateur

Should : second facteur TOTP, journal d'audit chaîné par hachage, tableau de bord de supervision, rôle Auditeur, pièce jointe unique au rapport ($\leq$ 64 Ko), double approbation des enrôlements par deux administrateurs. **Could** : expiration automatique des livraisons.

3.2 Règles de gestion

— **RG-01** : échanges inter-agences uniquement (VOSTOK $\leftrightarrow$ LONGWEI).

— **RG-02** : le destinataire doit avoir un certificat valide, non révoqué et émis par la CA du projet.

— **RG-03** : le paquet dissimulé ne dépasse pas 25 % de la capacité utile de l'image.

— **RG-04** : image porteuse = PNG vérifié par son contenu (pas par l'extension), $\leq$ 5 Mo, dimensions minimales 1024×768 et capacité utile au moins égale à quatre fois la taille du paquet.

— **RG-05** : chaque livraison reçoit un identifiant aléatoire non devinable (UUIDv4), une empreinte unique et un identifiant de filigrane, dont la correspondance est stockée de façon intègre. L'identifiant de livraison n'est jamais un jeton d'accès : chaque requête vérifie que l'appelant est l'expéditeur ou le destinataire.

— **RG-06** : le serveur ne stocke ni clé privée d'agent ni rapport en clair ; l'image porteuse d'origine est supprimée après dissimulation (seule l'image finale est conservée).

— **RG-07** : les comptes sont créés sur invitation uniquement.

— **RG-08** : l'approbation d'un enrôlement journalise l'empreinte de la clé ; les agents peuvent comparer cette empreinte hors bande avant de s'échanger des rapports ; la double approbation est prévue en Should.

3.3 Scénarios principaux

1. **Envoi** (figure 1). Certificat révoqué ou capacité dépassée : livraison refusée.
2. **Réception** (figure 2). Signature invalide : avertissement explicite, rapport non présenté comme authentique. Le serveur n'a jamais accès au clair.
3. **Fuite.** L'administrateur soumet une image suspecte ; le serveur extrait filigrane et empreinte, vérifie leur authenticité et désigne la livraison concernée. Marque absente ou invalide : résultat « non concluant ».

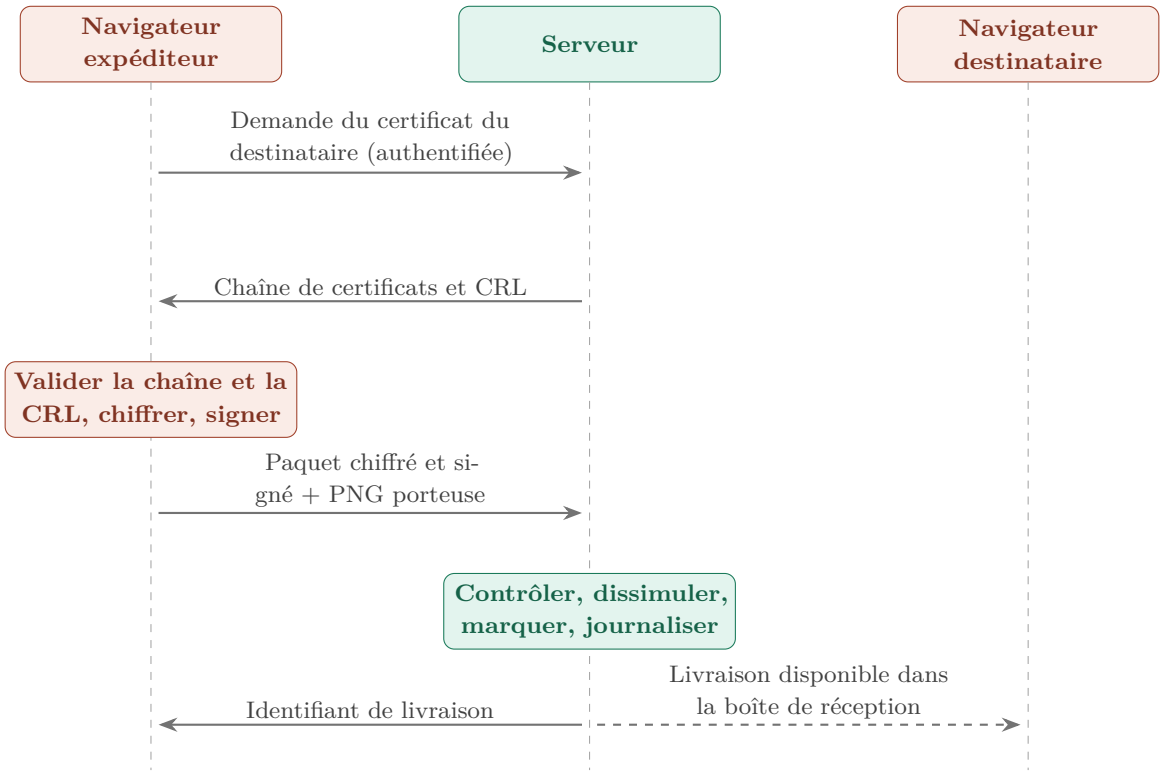


FIGURE 1 – Flux d'envoi d'un rapport (EF-05 à EF-11)

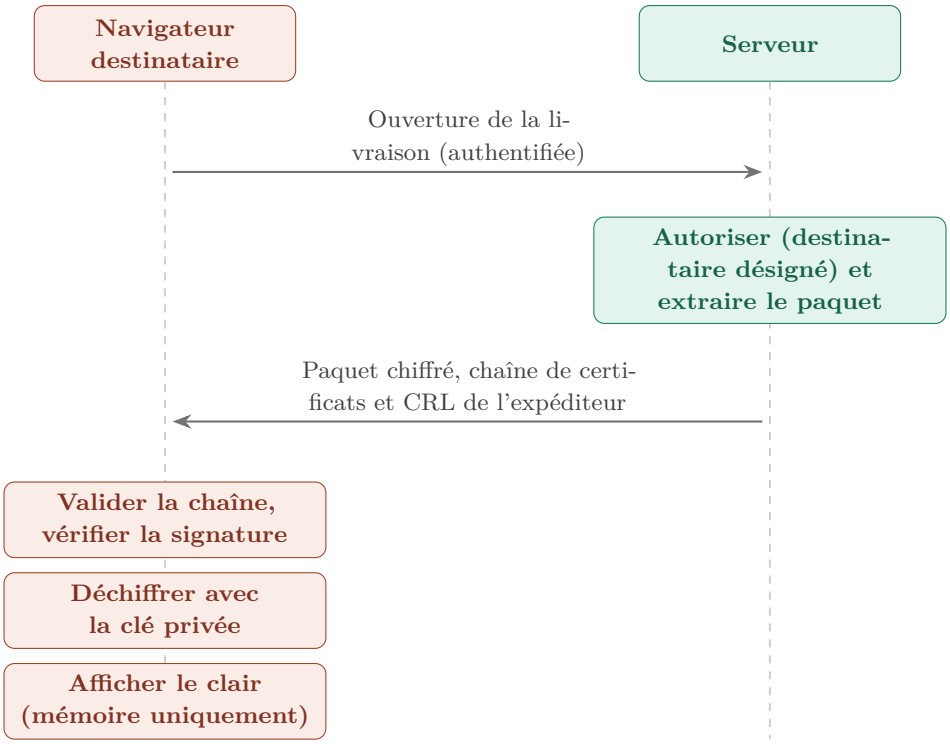


FIGURE 2 – Flux de réception d'un rapport (EF-11, EF-12)

4 Conception technique

4.1 Architecture

Contraintes imposées : Jakarta EE 11, WildFly 42 et Java 25 côté middleware ; client PWA/SPA.

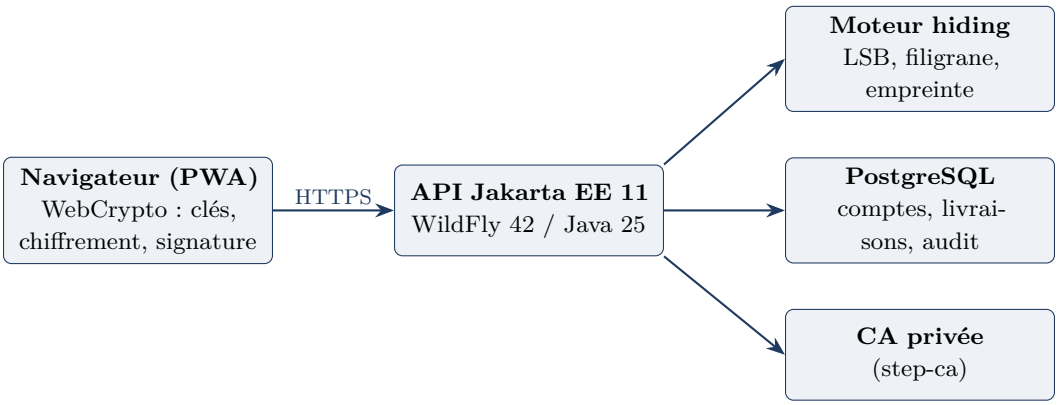


FIGURE 3 – Architecture générale de PhantomOps

Le tableau suivant détaille les composants de la figure 3.

Composant	Technologies	Responsabilités
Front PWA/SPA	TypeScript, framework JS léger, WebCrypto, service worker	Interface ; génération des clés (non exportables), chiffrement, signature, déchiffrement, vérification de signature et de la chaîne du certificat (racine de confiance embarquée)
API	Jakarta REST, CDI, Jakarta Security, Bean Validation	Authentification, autorisation, validation des entrées, contrôle de la chaîne du certificat destinataire
Persistance	Jakarta Persistence, PostgreSQL	Comptes, livraisons, journal d'audit
Moteur d'information hiding	Module Java autonome (`javax.imageio`)	Dissimulation, extraction et marquage avec la clé de marquage du serveur ; ne manipule que des données chiffrées
PKI	step-ca en conteneur ; backend en autorité d'enregistrement ; `CertPathValidator`	Certificats, CRL
Exécution	Docker Compose (WildFly, PostgreSQL, CA), TLS 1.3 de préférence	Déploiement reproductible

4.2 Paramètres cryptographiques

Fonction	Choix
Accord de clé	ECDH P-256 (clé éphémère côté expéditeur)
Dérivation de clé	HKDF-SHA-256
Chiffrement	AES-256-GCM
Signature	ECDSA P-256 / SHA-256
Marques	Identifiant + HMAC-SHA256 tronqué (non forgeable sans la clé serveur)
Mots de passe	Argon2id via bibliothèque éprouvée
Stéganographie	LSB à positions pseudo-aléatoires dérivées d'une clé de positionnement

La clé de positionnement n'est pas une clé de confidentialité : celle-ci repose uniquement sur le chiffrement de bout en bout. Ces choix pourront évoluer dans le document d'exigences.

4.3 Modèle de données

Entité	Attributs principaux
Utilisateur	identifiant, agence, rôle, condensat Argon2id, état du compte (invité, actif, désactivé)
Certificat	numéro de série, utilisateur, clé publique, dates de validité, état (en attente, émis, révoqué)
Livraison	identifiant, expéditeur, destinataire, date, empreinte, identifiant de filigrane et code d'authentification, référence de l'image
Événement d'audit	horodatage, acteur, action, objet, résultat, condensat de l'entrée précédente (chaînage)

4.4 Exigences non fonctionnelles

— **Performance** : dissimulation d'un paquet de 16 Ko dans un PNG de 5 Mo en 10 s au plus.

— **Compatibilité** : Chromium et Firefox récents (WebCrypto, service worker).

— **Qualité** : tests unitaires du moteur (aller-retour, capacité, images invalides), couverture $\geq$ 80 % sur ce module.

— **Maintenabilité** : build reproductible, README d'installation, intégration continue à chaque pull request.

— **Ergonomie** : parcours d'envoi en 5 étapes au plus.

5 Sécurité

5.1 Approche SRE : les cas d'abus

L'équipe retient les **cas d'abus** (*abuse cases*), prolongés par des cas d'utilisation de sécurité. Un cas d'abus décrit ce qu'un attaquant tente de faire et que le système ne doit pas permettre ; à chacun répond au moins une exigence de sécurité `SR-xx`, mesurable et testable. Ce choix convient à un système adversarial comme PhantomOps, où les marques n'ont de valeur que face à un attaquant qui cherche à les effacer ou les forger. Il est aussi proportionné à un binôme et donne une traçabilité directe : `AC-xx` → `SR-xx` → chapitre → test.

SQUARE, les récits d'abus et de sécurité, les arbres d'attaque, UMLsec, SERA et OCTAVE sont écartés (trop lourds ou peu adaptés à un binôme) ; la comparaison figure dans le document d'exigences (§3.3).

5.2 Périmètre de l'analyse

Les **actifs** protégés sont les rapports (C, I), les clés privées des agents (C), les clés de la CA (C, I), les clés de marquage et de positionnement (C, I), le journal d'audit (I), les comptes et sessions (C, I) et le service d'échange (D). Les **adversaires** sont l'attaquant externe, l'agent malveillant, l'administrateur curieux et le serveur compromis ; le serveur est par ailleurs supposé honnête mais curieux (hypothèses H-01 à H-05, document d'exigences §1.4).

Le document d'exigences recense **25 cas d'abus** et **40 exigences de sécurité** (36 Must, 4 Should), réparties selon les six types du cours : identification et authentification, autorisa-

tion, intégrité et confidentialité, non-répudiation, détection d'intrusions et audit, résilience et disponibilité. Les exclusions de la section 2.3 y sont traitées comme risques résiduels.

5.3 Correspondance avec le programme du cours

Chapitre	Application dans PhantomOps
2. Méthodologies, spécification, conception	Cas d'abus, exigences SMART, matrice de traçabilité
3. Confidentialité, intégrité, disponibilité	Chiffrement de bout en bout, signatures, TLS, limites d'upload, protection contre les images piégées (pixel flood)
4. Authentification, autorisation, informations privées	Authentification, RBAC et règle inter-agences, protection contre l'IDOR, minimisation des données personnelles
5. Journalisation et gestion des erreurs	Journal d'audit sans secrets, erreurs génériques côté client, alertes
6. Tests de sécurité	Analyse statique, tests d'autorisation, fuzzing du parseur d'images, tests des cas d'abus
7. Déploiement et maintenance	Durcissement WildFly, gestion des secrets, suivi des dépendances

6 Organisation du projet

6.1 Planning

Le calendrier couvre quatre semaines de réalisation après la remise des documents.

Semaine	Objectifs	Livrables
S0	Dépôt GitHub, cahier des charges, document d'exigences	PDF sous `/docs`
S1	Squelette Jakarta EE sur WildFly 42, PWA minimale, authentification, schéma de données, intégration continue	EF-01, EF-02, EF-16
S2	Moteur d'information hiding, cryptographie navigateur	EF-06 à EF-09
S3	PKI, autorisation, livraison, extraction, vérification de fuite	EF-03 à EF-05, EF-10 à EF-13
S4	Journal d'audit, administration, tests de sécurité, déploiement Docker, documentation	EF-14, EF-15, rapport de tests

6.2 Répartition et méthode de travail

Mohamed Fourat Boujdaria prend le backend, le moteur d'information hiding et ses tests ; Cheikh Brahim prend la PWA, la cryptographie navigateur, la PKI et l'administration. Exigences, tests de sécurité et déploiement sont partagés ; chaque pull request est relue par l'autre membre.

Les tickets GitHub Issues sont étiquetés `abuse-case`, `security-requirement`, `feature` et `requirement-change` ; chaque cas d'abus et chaque exigence de sécurité porte un identifiant `AC-xx` ou `SR-xx` référencé dans le code et les tests. Le document d'exigences évolue avec le cours : toute modification passe par une issue `requirement-change` puis par une pull request relue par l'autre membre, et chaque changement est daté et justifié dans l'historique des versions. Une tâche est « terminée » lorsque le code est relu, les tests (dont les tests d'abus associés) sont écrits, les exigences liées sont vérifiées et la documentation est à jour.

6.3 Risques et plan de repli

Risque	Gravité	Parade
Calendrier trop ambitieux	Élevée	Ordre de coupe ci-dessous
Complexité de la PKI et de l'enrôlement	Moyenne à élevée	CA outillée ; en dernier recours, certificats émis par script d'administration
Support WebCrypto (clés non exportables)	Moyenne	Cibler Chromium et Firefox ; test précoce en S1
Compatibilité WildFly 42 / Java 25 / Jakarta EE 11	Faible à moyenne	Vérification de l'environnement dès S1

Ordre de coupe en cas de retard : (1) tableau de bord et TOTP ; (2) filigrane, en conservant l'empreinte ; (3) CRL publiée remplacée par une table de révocation interne ; (4) enrôlement avec approbation remplacé par des certificats émis par script. **Noyau à ne jamais couper** : chiffrement de bout en bout, signature, dissimulation, empreinte, autorisation et journal d'audit.